

Part 2: Security Frameworks In Depth

Security frameworks provide structured guidelines for organizations to build, improve, and evaluate their cybersecurity programs. The two primary frameworks studied are the NIST Cybersecurity Framework (CSF) and ISO 27001.

2.1 NIST Cybersecurity Framework (CSF)

Overview

The NIST CSF was developed by the National Institute of Standards and Technology (NIST) in 2014 and updated in 2024 (Version 2.0). It provides a risk-based approach to managing cybersecurity risk and is organized into five core functions: Identify, Protect, Detect, Respond, and Recover.

Function	Goal	Key Activities	Real-World Example
IDENTIFY	Understand the business context and cybersecurity risks.	Asset Management, Risk Assessment, Governance, Supply Chain Risk	Create an inventory of all servers, applications, and data assets. Identify which are critical to business operations.
PROTECT	Implement safeguards to ensure delivery of critical services.	Access Control, Encryption, Awareness Training, Secure Configuration	Enable MFA for all user accounts. Encrypt sensitive data at rest and in transit. Conduct quarterly security training.
DETECT	Identify the occurrence of a cybersecurity event.	Security Monitoring, Anomaly Detection, SIEM Alerting, Log	Deploy a SIEM (e.g., Wazuh) to alert on suspicious login attempts, PowerShell execution, and lateral movement.



Function	Goal	Key Activities	Real-World Example
		Analysis	
RESPOND	Take action regarding a detected cybersecurity incident.	Incident Response Plan, Communication, Mitigation, Forensic Analysis	Execute IR playbook: isolate infected host, notify stakeholders, preserve evidence, block attacker's IP.
RECOVER	Restore capabilities impaired by a cybersecurity incident.	Recovery Planning, Backup Restoration, Lessons Learned, Improvement	Restore systems from clean backups, verify integrity, conduct post-incident review, and update security controls.

NIST CSF Implementation Tiers

Tier	Name	Description
Tier 1	Partial	Ad-hoc and reactive. No formal risk management process. Security practices are not consistently applied.
Tier 2	Risk-Informed	Risk management practices are approved but not organization-wide. Awareness of cybersecurity risk exists.
Tier 3	Repeatable	Formally approved, regularly updated risk management practices. Consistent organization-wide implementation.
Tier 4	Adaptive	Organization adapts cybersecurity practices based on lessons learned and predictive indicators. Continuous improvement culture.

2.2 ISO 27001 Controls

Overview

ISO 27001 is an international standard for Information Security Management Systems (ISMS). It contains 114 controls organized across 14 domains (Annex A). Organizations use these controls to systematically manage and protect information assets.

3 Key Controls Applied to Ransomware Mitigation

Control	Domain	Title	How It Helps Against Ransomware
A.12.3.1	Operations Security	Information Backup	Requires regular backups of critical data to be taken, tested, and stored securely (ideally offline/off-site). If ransomware encrypts files, verified backups allow restoration without paying the ransom.
A.12.4.1	Operations Security	Event Logging	Requires logging of user activities, exceptions, and security events. Ransomware indicators (mass file encryption, suspicious processes) appear in logs, enabling early detection through SIEM correlation.
A.14.2.5	System Development	Secure Development Principles	Requires security to be built into software from the ground up. Reduces vulnerabilities in internally developed applications that ransomware could exploit for initial access or privilege escalation.
A.8.2.1	Asset Management	Classification of Information	Requires information to be classified (e.g., Public, Internal, Confidential, Secret). Helps organizations prioritize which data requires the strongest protection and most frequent backups.

Control	Domain	Title	How It Helps Against Ransomware
A.6.1.2	Organization of Security	Segregation of Duties	Prevents a single user from having access to all systems. Limits the blast radius of ransomware — if one account is compromised, segregation prevents it from encrypting everything.

2.3 WannaCry Ransomware — NIST CSF Mapping

Background

WannaCry (May 2017) was a global ransomware attack that infected over 200,000 computers in 150 countries within 24 hours. It exploited the EternalBlue vulnerability (MS17-010) in Windows SMB protocol, which was a leaked NSA exploit. Major victims included the UK NHS, Telefonica, FedEx, and Deutsche Bahn.

NIST CSF Function	WannaCry Failure	Recommended Action	Control Reference
IDENTIFY	Organizations had not inventoried unpatched Windows systems running vulnerable SMB v1.	Maintain asset inventory. Flag all systems missing critical patches. Know your attack surface.	NIST ID.AM, ISO A.8.1.1
PROTECT	MS17-010 patch was available since March 2017 — 2 months before	Patch systems immediately when critical updates release. Disable legacy protocols	NIST PR.IP, ISO A.12.6.1

NIST CSF Function	WannaCry Failure	Recommended Action	Control Reference
	the attack. Many orgs had not applied it. SMB v1 was not disabled.	(SMBv1). Segment networks to prevent lateral spread.	
DETECT	Most organizations had no IDS/IPS monitoring for EternalBlue exploit patterns on internal networks.	Deploy network IDS (Suricata) to alert on SMB exploit attempts (Event ID 4624, 4625). Enable file-change monitoring to detect mass encryption.	NIST DE.CM, ISO A.12.4.1
RESPOND	Many organizations were slow to isolate infected systems, allowing WannaCry to spread further internally.	Execute IR playbook immediately: isolate infected hosts from network, block TCP port 445, notify CISA/NCSC, preserve disk images for forensics.	NIST RS.MI, ISO A.16.1.5
RECOVER	Organizations without backups faced weeks of downtime. UK NHS cancelled 19,000 appointments.	Restore from offline backups. Verify backup integrity before connecting to network. Implement 3-2-1 backup rule (3 copies, 2 media types, 1 offsite).	NIST RC.RP, ISO A.12.3.1